

Informe de Pentesting

Actividad A08 - Hacking Etico - Cliente: INSECUR S.A.

Seguridad Aplicada a Sistemas de Informacion - Licenciatura en Sistemas de Informacion

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Gaston Alvarez
DNI	46.234.885
Username TryHackMe	gastonalvarez
Email institucional	alvarezgaston@uch.edu.ar
Sala de eleccion (Nivel 2)	Blue (Windows - EternalBlue / MS17-010)
Branch en GitHub	alvarez-gaston
Fecha de inicio	03/10/2026
Fecha de cierre	09/10/2026

2. Pre-pentesting

Alcance del trabajo

El alcance autorizado comprende exclusivamente las maquinas de laboratorio provistas por la plataforma TryHackMe en el marco de esta actividad academica: la sala obligatoria Basic Pentesting (Nivel 1) y la sala de eleccion Blue (Nivel 2). Queda excluido cualquier sistema real o ajeno a los entornos de laboratorio asignados.

Reglas de Enfrentamiento (ROE)

El trabajo se realizo dentro de los horarios de estudio del alumno, conectado unicamente a traves de la VPN oficial de TryHackMe. No se aplicaron tecnicas de denegacion de servicio. No se registraron incidentes que requirieran notificacion inmediata al docente.

Autorizacion

Se declara contar con autorizacion expresa de la cathedra de Seguridad Aplicada a Sistemas de Informacion (FID-UCH) para operar sobre los entornos de TryHackMe indicados en la guia de la actividad A08.

Metodologia utilizada

Se siguio el flujo profesional de pentesting propuesto en la guia de cathedra (basado en PTES / NIST SP 800-115): reconocimiento, escaneo, enumeracion, explotacion, postexplotacion y reporte. Se eligio este marco por ser el sugerido por la cathedra y por su adecuacion a un ejercicio acotado en salas de laboratorio.

3. Durante: Hallazgos por fase

3.1 Sala Basic Pentesting (Nivel 1 - Nucleo obligatorio)

Reconocimiento y escaneo: se identifico la maquina objetivo mediante nmap, detectando puertos SMB (139/445) y SSH (22) abiertos.

Enumeracion: via enum4linux/SMB se obtuvo un listado de usuarios validos del sistema.

Explotacion: se realizo fuerza bruta sobre el servicio SSH con hydra utilizando el listado de usuarios obtenido y la wordlist rockyou.txt, logrando obtener credenciales validas.

Postexplotacion: una vez dentro, se localizo una clave privada SSH perteneciente a otro usuario del sistema, permitiendo la escalada de privilegios hasta obtener acceso completo y la contraseña final solicitada por la sala.

3.2 Sala Blue (Nivel 2 - Eleccion, Windows)

Reconocimiento: nmap identifico la maquina objetivo como Windows Server 2012 R2 Datacenter, con los puertos 135, 139, 445, 3389, 5985 y varios puertos RPC dinamicos (49152-49175) abiertos. El analisis de SMB (smb-os-discovery, smb-security-mode) evidencio una configuracion con firma de mensajes SMB no obligatoria, un indicador tipico de vulnerabilidad a exploits de la familia EternalBlue.

Comando de verificacion de vulnerabilidad:

```
nmap --script smb-vuln-ms17-010 -p445 <IP_OBJETIVO>
```

Resultado: la maquina fue confirmada como VULNERABLE a MS17-010 (CVE-2017-0143), con nivel de riesgo HIGH segun la propia salida del script de nmap.

Explotacion: se utilizo el framework Metasploit. El primer intento se realizo con el modulo exploit/windows/smb/ms17_010_eternalblue, que si bien confirmo la vulnerabilidad en cada corrida, no logro establecer sesion en multiples intentos (fallas de tipo INVALID_PARAMETER y timeout de socket), un comportamiento conocido de este modulo por depender de una condicion de carrera sensible a la latencia de red. Se opto entonces por el modulo exploit/windows/smb/ms17_010_psexec (familia EternalRomance/EternalSynergy/EternalChampion), seleccionando el target 'Native upload' para evitar la entrega via PowerShell.

Durante el proceso se detecto que el parametro LHOST del payload apuntaba a una direccion de VPN desactualizada de una sesion anterior; una vez corregido a la IP vigente de la interfaz tun0, el exploit logro ejecutarse con exito, obteniendo una sesion Meterpreter con privilegios NT AUTHORITY\SYSTEM.

Confirmacion de acceso:

```
getuid -> Server username: NT AUTHORITY\SYSTEM sysinfo -> Windows Server 2012 R2 (6.3 Build 9600), x64
```

Postexplotacion: con la sesion Meterpreter activa se realizo un dump de credenciales con el comando hashdump, obteniendo los hashes NTLM de las cuentas locales (Administrator, Guest y el usuario no-default Jon). El hash de Jon fue extraido a un archivo y sometido a un ataque de diccionario con John the Ripper (formato NT, wordlist rockyou.txt), logrando crackear la contraseña en texto plano en menos de un segundo.

```
john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt jon_hash.txt ->
Contraseña obtenida: alqfna22
```

Adicionalmente se localizaron y extrajeron tres archivos "flag" ubicados en puntos clave del sistema (raíz del disco C:, carpeta de configuración SAM y carpeta de documentos del usuario Administrator), utilizados como evidencia de progreso en cada etapa del compromiso.

4. Tabla de hallazgos

Campo	H-01
Fase	Explotación / Postexplotación
Descripción	Ejecución remota de código sin autenticación vía SMBv1 (EternalBlue), resultando en acceso SYSTEM
Componente afectado	Servicio SMB (puerto 445) - Windows Server 2012 R2
Categoría (CWE)	CWE-787 (escritura fuera de límites) explotada vía SMBv1
CVE	CVE-2017-0143 (MS17-010)
CVSS estimado	Crítico
Herramienta utilizada	nmap (detección), Metasploit Framework (explotación), John the Ripper (cracking)
Impacto en la triada CIA	Confidencialidad, Integridad y Disponibilidad - compromiso total del sistema
Salvaguarda propuesta	Deshabilitar SMBv1, aplicar el parche MS17-010, segmentar la red y exigir firma de mensajes SMB
Riesgo residual tras aplicar	Bajo

5. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	1	H-01
Alto	0	-
Medio	0	-
Bajo	0	-
Total	1	-

6. Post-pentesting: Recomendaciones

Recomendaciones técnicas

- Aplicar de forma inmediata el parche de seguridad MS17-010 en todos los equipos con Windows Server 2008 R2 a 2016 expuestos.
- Deshabilitar el protocolo SMBv1 en toda la red, reemplazándolo por SMBv2/v3.
- Exigir firma de mensajes SMB (message signing) en todos los hosts.
- Restringir la exposición del puerto 445 a segmentos de red no confiables mediante firewall.
- Implementar políticas de contraseñas robustas; la contraseña del usuario local crackeada en segundos evidencia una política débil.

Recomendaciones administrativas

- Incorporar un proceso periodico de gestion de parches (patch management) con plazos maximos de aplicacion segun criticidad.
- Realizar escaneos de vulnerabilidades recurrentes sobre los servidores de produccion.
- Capacitar al equipo de IT en practicas de endurecimiento (hardening) de servidores Windows.
- Revisar y actualizar la politica de contraseñas corporativa, incluyendo verificación contra diccionarios conocidos (rockyou y similares).

7. Protocolo de contingencia

Escenario de falla

La aplicacion de un parche de seguridad critico como MS17-010 (que puede requerir reinicio del servidor) podria interrumpir temporalmente los servicios que dependen de dicho servidor Windows.

Impacto sobre la continuidad del negocio

De tratarse de un servidor de archivos o de autenticacion en produccion, la interrupcion afectaria el acceso a recursos compartidos y la operatoria de los usuarios dependientes de ese servidor durante el tiempo de parcheo y reinicio, estimado en no mas de 30 minutos.

Plan de respuesta

- Activacion: deteccion mediante monitoreo de disponibilidad del servicio o reporte de usuarios.
- Contencion: aislar el servidor afectado de la red hasta confirmar el estado del parche y notificar a los responsables de IT.
- Recuperacion: aplicar el parche en ventana de mantenimiento programada, con respaldo previo y plan de rollback mediante snapshot o backup del servidor.
- Comunicacion: notificar a los responsables de sistemas y, de corresponder, a los usuarios afectados con anticipacion a la ventana de mantenimiento.
- Post-mortem: documentar el incidente o la intervencion, registrar tiempos y actualizar el procedimiento de parcheo.

RTO y RPO estimados

RTO (Recovery Time Objective): 30 minutos.

RPO (Recovery Point Objective): 24 horas (frecuencia de backup diaria recomendada).

8. Anexos

Anexo A - Bitacora de comandos: ver archivos en bitacora/ del repositorio (nmap_blue_inicial.txt, nmap_blue_vuln_ms17010.txt, jon_hash.txt, entre otros).

Anexo B - Capturas de pantalla: ver carpeta evidencias/ con subcarpetas por fase.

Anexo C - Hashes de las flags obtenidas:

```
H-01 (flag1) sha256sum de:  
flag{d993d772601d8863beb7a721df19d7d372447e2b11e085334418252cf8f9abb3  -}  
  
H-02 (flag2) sha256sum de:  
flag{a9ce99cec8c124b6a1f2e8488b4c9212aba6ad902c45177513d17d345e49a849  -}  
  
H-03 (flag3) sha256sum de:  
flag{5d78372a8b652a1d1fc20ad848e12b6efab324ae5e627c9a4c25984c38df039e  -}
```

Anexo D - Declaracion etica: declaro que todas las actividades se realizaron dentro del alcance autorizado, en entornos controlados (TryHackMe) y con fines exclusivamente academicos.